

Passive IPsec VPN Protocol Analysis Platform — PRD v3

2026-09-20 · @Someone

Overview

A security analysis platform that takes captured or live IPsec VPN traffic, reconstructs the deployment's protocol and cryptographic characteristics, infers what kind of traffic is moving inside the encrypted tunnel, and produces an evidence-backed security assessment.

The design principle: **establish what is observable, eliminate what is arithmetically impossible, rank only what survives — and never let a model resurrect a candidate that arithmetic has ruled out.**

What changed from v1

Version 1 was structurally sound but rested on an assumption that does not survive contact with modern IPsec. It treated the control plane as fully parseable and reserved inference for ESP payloads only. For IKEv2 this is backwards: the control plane is where the hard inference problem lives.

Five changes follow from that.

1. **Control-plane inference is now a core subsystem**, not a footnote. PFS, authentication method, tunnel mode and rekey behaviour are recovered from size, timing and structural side channels rather than claimed as parsed facts.
2. **Implementation fingerprinting moves from Future to MVP**. It is the mechanism that bridges the observability gap, and it is the single highest-value-per-effort component in the product.
3. **Traffic classification is windowed, not per-flow**. Tunnel mode multiplexes many inner conversations onto one SPI pair, so per-flow classification is not merely hard, it is undefined.
4. **Coverage is a first-class output**. The system reports what it could not assess with the same prominence as what it could.
5. **The ML evaluation protocol is specified explicitly**, because a lab dataset will otherwise hand you 99% accuracy that means nothing.

The anti-agentic position from v1 is retained and strengthened. The problem is a pipeline with known stages, not a dynamic investigation, and multi-agent orchestration would add hallucination risk and debugging cost for no analytical gain.

What changed in v3

Version 2 identified the right constraint — IKEv2 hides the Child SA — but answered it with a probabilistic mechanism: fingerprint matching supplying implementation defaults. Three findings force a different answer, and they reorder the whole document.

Defaults-based inference is anti-correlated with the use case. A tunnel running vendor defaults is usually a tunnel that is fine. The tunnels this platform exists to find — configured by hand years ago and never revisited — are non-default by construction. A defaults-first system is most confident exactly where it is least useful, and silently wrong exactly where being right matters. Fingerprint defaults remain in the design, demoted from primary mechanism to tie-breaker.

ESP framing is arithmetic, not inference. RFC 4303 fixes how IV length, padding granularity and ICV length combine, which constrains observed ESP lengths to a lattice that can be *solved* rather than predicted. This moves the bulk of ESP suite recovery out of the model and into a deterministic engine that emits a printable derivation.

The question the user asks is coarser than the question v2 tried to answer. NTRO asks whether a tunnel is weak, not which cipher it runs. A risk verdict is frequently decidable across a candidate set even when cipher identity is not — every member of a surviving set may agree on compliance. Ambiguity stops being a caveat and becomes something the system reasons over.

One further change is external. In July 2026 the IETF assigned notify type 16447, `IKE_SA_INIT_FULL_TRANSCRIPT_AUTH`, in the plaintext `IKE_SA_INIT` exchange, and Cloudflare shipped support days later. Its presence or absence is a deterministic, high-severity finding that did not exist when v2 was written, and it is now the platform's headline differentiator.

The consequence for ordering: the claim ledger, downgrade exposure and deterministic identity lead. Traffic classification is the fourth chapter, not the first.

The central technical constraint

IKEv2 encrypts most of what this platform is asked to assess. Any team that does not confront this will either fabricate values or silently report defaults as findings.

Only `IKE_SA_INIT` is plaintext. Everything from `IKE_AUTH` onward travels inside an encrypted `SK{}` payload, which includes the Child SA proposal — that is, the ESP cipher and integrity algorithm themselves.

What is and is not available

Parameter	IKEv2	IKEv1	How obtained
IKE version	Visible	Visible	Parsed
IKE SA cipher, integrity, PRF	Visible	Visible	Parsed
DH group	Visible	Visible	Parsed
NAT presence	Visible	Visible	Parsed
Identities	Hidden	Aggressive Mode leaks	Parsed or unavailable
IKE SA lifetime	Hidden	Main Mode visible	Parsed or inferred
Auth method	Hidden	Partly visible	Inferred
ESP cipher and integrity	Hidden	Hidden	Fingerprint default
Tunnel vs transport	Hidden	Hidden	Inferred
PFS	Hidden	Hidden	Inferred from rekey size
Child SA lifetime	Hidden	Hidden	Measured from rekeys
ESN	Hidden	Hidden	Weakly inferred
Anti-replay window	Hidden	Hidden	Not observable
Traffic inside ESP	Hidden	Hidden	ML inference

Two consequences shape the product.

The first is that **assessment coverage is paradoxically higher on IKEv1**, the protocol the tool is supposed to flag as weaker. Main Mode exposes phase-1 proposals including lifetime attributes. This is worth stating in the report rather than hiding.

The second is that a security assessment engine built only on parsed fields would have almost nothing to say about a modern IKEv2 capture. Recovering the hidden column is therefore not an enhancement — it is what makes the product work at all.

Anti-replay deserves a specific note because it is the most commonly misreported parameter in tools of this kind. It is receiver-side policy. The ESP sequence number is always present regardless of whether a replay window is enforced, so observing the field proves nothing. The honest output is `not_observable`.

Goals and non-goals

Goals

1. Accept IPsec packet captures and live network streams through one analysis path.
2. Identify IPsec, IKE version and negotiated IKE SA parameters from observable fields.
3. Detect structural exposure to the IKEv2 downgrade attack classes, and report post-quantum posture, from plaintext notify presence alone.
4. Constrain the ESP cipher and integrity algorithm by packet-framing arithmetic, and resolve the risk question over the surviving candidate set even where cipher identity stays ambiguous.
5. Recover authentication method, PFS, operating mode and rekey behaviour by inference where encryption hides them.
6. Reconstruct the Security Association graph, including rekey lineage.
7. Identify the peer implementation by exact vendor-ID lookup where one exists, and use its documented defaults only to rank candidates that deterministic constraints have already admitted.
8. Classify the traffic carried inside ESP without decryption, per time window, with calibrated confidence and the ability to abstain.
9. Evaluate observed and inferred configuration against a declared security policy.
10. Report coverage — what could not be assessed — alongside every finding and score.
11. Produce an executive report, a technical report, a risk score, a threat matrix and a confidence score.
12. Keep observed facts, inferences and policy judgements visibly distinct at every layer.

Non-goals

The system does not exploit vulnerabilities, decrypt arbitrary traffic, or replace a penetration test. It does not use an LLM to determine any protocol field, severity or traffic class. It does not identify specific applications such as WhatsApp from encrypted traffic, only broad behavioural classes.

On remediation

This distinction matters and the two halves are often conflated.

In scope: advisory recommendations. The problem statement asks for actionable recommendations, so every policy rule carries recommendation text and both reports render it. Recommendations are phrased as areas for review.

Out of scope: automated remediation. The system never modifies a VPN configuration, generates a config file, pushes a change to a device, or offers an apply action. There is no "Fix" button anywhere in the product.

The reasoning is not only scope discipline. The platform is a passive observer working substantially from inference; a system that acts on inferred configuration state could break a working VPN on the strength of a probabilistic claim. Advisory output keeps the human in the position to catch that.

Users

User	Needs to know	Uses
Security analyst	Is this VPN configured safely, and what is it carrying?	Executive report, threat matrix, findings
Network engineer	What was negotiated, and what is actually running?	SA reconstruction, technical report, evidence explorer
Researcher or student	How does IPsec behave, and what can be inferred from it?	Testbed, dataset, model card, provenance view

The analyst's job is the design target. They arrive with a capture and a question, and they need an answer they can defend to someone else.

That last clause drives the provenance model. An answer an analyst cannot trace back to a frame is an answer they cannot use.

The provenance model

This is a product requirement, not an implementation choice. It determines what the user is shown and what the policy engine is allowed to act on.

Every value the system holds is a Claim carrying a field, a value, a provenance tier, a confidence, the method that produced it, evidence references and any caveats.

Tier	Meaning	Policy engine may act on
<code>observed</code>	Parsed from a plaintext protocol field	Always
<code>inferred_side_channel</code>	Derived from size, timing or structure	If the rule permits
<code>inferred_implementation_default</code>	From a matched implementation profile	Only for advisory findings
<code>ml_prediction</code>	Classifier output	Metadata findings only
<code>not_observable</code>	Undeterminable from this capture	Never; emits a coverage gap

The no-promotion rule

A claim may never move to a higher tier. Not because confidence is high, not because two inferences agree, not because the report would read better.

This is enforced in the claim type itself rather than left to developer discipline. It is the difference between a tool an analyst can rely on and one that sounds authoritative.

Elimination versus ranking

The no-promotion rule states what may not happen. This states the mechanism that makes it structural rather than a matter of developer discipline.

Evidence in this system does one of two things, and the two are never mixed. It **eliminates** — a hard constraint that removes candidates from a set, deterministic and reproducible — or it **ranks** — a soft prior that reorders whatever survives. Framing arithmetic eliminates. Plaintext protocol fields eliminate. Implementation fingerprints and classifier outputs only ever rank.

Every inference over a closed parameter space therefore runs the same shape: enumerate the universe of candidates, apply every hard constraint to produce a feasible set, then rank within that set and never outside it. The feasible set is final once the

deterministic stage completes. No posterior, however confident, may add a member back.

This is what bounds the damage a bad model can do. A fingerprint trained on two implementations and pointed at a Fortinet gateway will misrank; it cannot manufacture a cipher suite that packet arithmetic has already disproved. Degraded ordering is a recoverable failure. A fabricated parameter in a security report is not.

Conflict handling

When an observed claim contradicts an inferred one for the same field, the observed value wins and the contradiction is recorded as its own finding.

A disagreement usually means one of two things: the inference heuristic is broken, or the peer deviates from its implementation's documented defaults. Both are worth surfacing rather than smoothing over.

Functional requirements: ingestion through features

F1 — Ingestion

Accept .pcap and .pcapng upload, and live capture via AF_PACKET with a narrow BPF filter. A third mode replays a stored capture into the live pipeline at wall-clock speed.

Both paths normalize to one internal record type before any analysis. No downstream module may distinguish file input from live input.

Large captures stream with bounded memory. Sampling is permitted only when disclosed in the report.

F2 — Protocol demultiplexing

Route UDP/500 to ISAKMP, UDP/4500 by non-ESP marker to either IKE or UDP-encapsulated ESP, IP protocol 50 to ESP, IP protocol 51 to AH, and TCP/4500 to RFC 8229 encapsulation.

AH is detected and flagged as deprecated. It is not analysed in depth and no AH captures are generated in the testbed.

F3 — IKE parsing

Parse all plaintext IKE content for IKEv1 and IKEv2. Do not implement a dissector from scratch — drive Wireshark's `isakmp` dissector and consume structured output.

For encrypted exchanges, record envelope metadata: length, message ID, exchange type, direction, timestamp, fragmentation state, and subsequent IKE SPI changes. Reassemble RFC 7383 fragments before any size-based analysis.

F3b — Notify posture and downgrade exposure

The headline deterministic finding. Everything it needs is already parsed by F3; it adds notify-type checks and one cross-reference, and it emits at the `observed` tier with confidence 1.0 and no model anywhere in the path.

[draft-ietf-ipsecme-ikev2-downgrade-prevention-08](#), dated 1 July 2026 and authored by Valery Smyslov and Christopher Patton, defines notify type **16447**, **IKE_SA_INIT_FULL_TRANSCRIPT_AUTH**, carried in the plaintext `IKE_SA_INIT` exchange. It closes key-compromise-impersonation and identity-misbinding downgrade attacks, formalised by [Bhargavan et al.](#) at IEEE S&P 2016. Cloudflare shipped [beta support](#) on 8 July 2026. IANA records 16447 as the last assigned status type in the registry.

Protection requires both peers to support the extension, and the responder sends the notify unconditionally when it supports it. Presence is therefore a four-state lattice, not a boolean.

Notify 16447	Interpretation	State
In request and response	Both peers support it; the handshake transcript is authenticated	Protected
Request only	Initiator supports it, responder does not	Partial — responder named
Response only	Responder advertises it; initiator does not support it	Partial — initiator named
Absent from both	Neither peer implements the extension	None

The two partial states are worth more to the report than the absent state, because they name the endpoint to fix. A Cloudflare-terminated tunnel with a legacy on-premise initiator lands in the response-only state, is not protected, and a boolean check would have passed it.

Severity is gated on whether the attack’s precondition is met, so that a strong deployment missing the extension does not generate noise that devalues the real findings.

- **High** — `ADDITIONAL_KEY_EXCHANGE` (notify 16441, [RFC 9370](#)) is present, meaning a hybrid post-quantum deployment, and the state is not Protected. This is the population the draft was written for: an organisation that has paid for post-quantum migration and remains exposed to the attack that migration made more relevant.
- **High** — the key-exchange proposal mixes weak groups (1, 2, 5, 22, 23, 24) with strong ones (14 and above, 19–21, 31), and the state is not Protected.
- **Medium** — any weak key-exchange group is negotiable and the state is not Protected.
- **Informational** — the state is not Protected but no weak method is negotiable.

The same module records post-quantum posture from the adjacent plaintext notifies:

`USE_PPK_INT` (16445) and `PPK_IDENTITY_KEY` (16446) from RFC 9867, and `ADDITIONAL_KEY_EXCHANGE` itself. These are presence checks on parsed fields, so post-quantum readiness is reported as observed fact rather than inferred.

This requirement has no testbed dependency. It is testable against synthetic `IKE_SA_INIT` messages and can ship before any capture exists.

F4 — SA reconstruction

Build a graph of IKE SA and Child SA nodes with parent links and rekey succession edges.

Child-to-parent linkage is temporal and topological, therefore inferential, and must be labelled `inferred` with confidence that degrades when multiple IKE SAs share an endpoint pair.

F5 — Control-plane inference engine

The differentiating subsystem. Each inference emits a claim with method, confidence, evidence and caveats, and each abstains rather than guessing when its preconditions are unmet.

Inference	Method	Abstains when
PFS	<code>CREATE_CHILD_SA</code> size vs SA baseline	No rekey observed; ECP ambiguity
Rekey type	IKE SPI change after exchange	Never; structural
Auth method	CERTREQ, round-trip count, size band	Capture starts after <code>IKE_AUTH</code>

Inference	Method	Abstains when
Mode	Inner-header arithmetic plus topology	Too few MTU-saturated packets
Rekey interval	Measured SPI succession	Capture shorter than interval
ESN	Sequence wrap without rekey	Short capture

F6 — ESP feature extraction

Compute features per SA per window, default 5 seconds, configurable.

Normalize for cipher overhead to estimate inner packet size before modelling. Without this step the classifier learns the cipher suite, which in a lab correlates with the capture config.

SPI values, addresses, ports and absolute timestamps are excluded from the feature set by construction, not by convention.

F6b — ESP suite constraint engine

The mechanism that recovers the parameter IKEv2 hides. It is arithmetic, not prediction, and it emits at the `inferred_side_channel` tier with a derivation the report can print.

Enumerate the universe of realistic ESP suites as cipher × key length × mode × integrity algorithm × ICV length — roughly 40 to 60 entries. Every step below is a set operation over that universe, which is what keeps the engine auditable.

Let `E` be the ESP bytes following the 8-byte SPI and sequence-number header, with the UDP header subtracted first under NAT-T, and `P` the inner plaintext length. RFC 4303 fixes the relationship.

```
\begin{aligned}
E_{\text{CBC}} &= b + \left\lceil \frac{P+2}{b} \right\rceil b + \text{ICV} \\
&\ll[4pt] \\
E_{\text{CTR}} &= 8 + \text{align}_4(P+2) + \text{ICV} \\
\end{aligned}
```

Alignment granularity by GCD. Take the pairwise differences of observed `E` across the flow and compute their greatest common divisor. The fixed overhead cancels, so the estimator needs no assumption about the plaintext length distribution — which is the

reason to prefer it over a fixed residue lookup, where the residue cannot be interpreted without already knowing the ICV length.

Cipher family	Explicit IV	Pad granularity	GCD of length differences
AES-CBC	16	16	16
3DES, DES, Blowfish, CAST (CBC)	8	8	8
AES-GCM, AES-CCM, AES-CTR, ChaCha20-Poly1305	8	4	4

A GCD of 8 is a deterministic weak-cryptography finding on its own: every 64-bit-block cipher still deployable in ESP is deprecated. No fingerprint and no model is consulted to reach it.

ICV length by known-plaintext-length anchoring. The GCD gives the cipher family but not the ICV, and ICV length is what decides the integrity verdict — 12 bytes means a truncated 96-bit MAC, all of which are deprecated under current guidance. Identify inner packets whose length is structurally forced: TCP pure ACKs at 40 bytes, or 52 with timestamps, which are the modal small packet in the reverse direction of any sustained unidirectional burst; the TCP handshake triple, which has a distinctive direction-and-timing signature; symmetric ICMP echo pairs. With one anchor of known `P`, the quantity `E - P` resolves IV plus padding plus ICV, and with the granularity already known the ICV follows exactly.

This industrialises an observation Izadinia et al. recorded in 2006 as an unvalidated partial discriminant, and it is the component that separates a confidence-1.0 integrity verdict from a guess.

Traffic-flow-confidentiality gate. TFC padding under RFC 4303 destroys the residue structure, and the failure is silent: the GCD degenerates and the arithmetic returns a confident-looking answer that is garbage. Detect it — length distributions too uniform, or respecting no consistent modulus — and hard-gate the whole engine to `not_observable`. A system that knows when it is blind is the one that survives an adversarial demonstration.

Output is a candidate set, never a point estimate. The engine returns the deterministic framing class, the surviving candidate set with its derivation, and an explicit `indistinguishable_within` field. Framing-identical suites cannot be separated by any

amount of modelling: AES-GCM-128, AES-GCM-256, AES-CCM and ChaCha20-Poly1305 at equal ICV produce byte-identical framing, and key length never changes framing at all. That ceiling is shipped in the output contract rather than buried in a caveat.

Verdict lifting. Evaluate each policy predicate across the whole surviving set. Where all members agree, emit the verdict at confidence 1.0 without identifying the cipher — a set whose every member is a 128-bit-or-better AEAD construction supports "confidentiality acceptable" with certainty. Where members disagree, emit `verdict_ambiguous`, name which candidates drive which outcome, and surface the F8 ranking as a tie-breaker marked at its own tier. This is the reason the platform can answer the question the user actually asked while remaining honest about the question it cannot.

Functional requirements: intelligence through delivery

F7 — AI traffic classification

Classify each window into one of seven classes: interactive real-time, streaming media, interactive web, bulk transfer, messaging and email, control and keepalive, and Unknown.

LightGBM is the primary model, with Random Forest and XGBoost as comparators. One 1D-CNN over the size and direction sequence may be evaluated. No LSTM or Transformer — the dataset cannot support the parameter count.

Probabilities must be calibrated on a held-out split before any confidence value is displayed. Abstention uses split conformal prediction producing a prediction set, with an out-of-distribution check alongside. The marginal variant is not sufficient here — the seven classes are imbalanced by construction, and marginal calibration systematically under-covers the rare ones. The engine uses clustered conformal prediction; the reasoning and its precondition are in the evaluation section.

Outputs per SA are a class timeline and a composition vector, not a single label. SHAP evidence accompanies every prediction.

The classifier's standing changed in v3. It is not the platform's differentiator and it does not determine any cryptographic parameter. Its two jobs are to characterise what is moving inside the tunnel, which is a question no deterministic method can answer, and to supply the metadata-exposure metric below. It never ranks a candidate the constraint engine has eliminated.

F8 — Implementation fingerprinting

Two paths, and the deterministic one runs first. Vendor ID payloads in `IKE_SA_INIT` are frequently the MD5 of a literal implementation string, sometimes with version bytes appended; [ike-scan](#) has maintained a public database of these for two decades. Match the hash prefix exactly, parse the version suffix where present, and the result is a lookup rather than an estimate.

Where no vendor ID matches — many stacks send none, or send an obfuscated one — fall back to structural fingerprinting: transform ordering, notify ordering, DH group preference, retransmission timing, cookie and fragmentation behaviour. That path returns a ranked match with a distance score and an explicit unknown-implementation outcome past a threshold, and it is labelled at its own tier so a reader can tell the lookup from the estimate.

A matched implementation and version is cross-referenced against a static CVE table. The chain is split so that no step overclaims: that the vendor ID asserts a version is `observed` ; that the asserted version falls inside a CVE's affected range is `observed` ; that the host is therefore vulnerable is neither, because backported fixes are routine. Findings are phrased as "asserted version falls in the affected range for CVE-YYYY-NNNN — verify patch level".

Matched profiles still supply defaults for ESP parameters, but only to rank within the feasible set F6b produces, and always labelled `inferred_implementation_default`.

F9 — Policy engine and coverage

Rules are declarative YAML with an id, target field, minimum provenance tier, condition, severity, references and recommendation text.

A rule whose provenance requirement is unmet emits a coverage gap rather than a finding. The engine reports assessable versus total checks as a headline output.

F10 — Scoring

Produce a risk score, a coverage score and a confidence score, each with published arithmetic and visible decomposition.

No score is ever displayed without its coverage beside it.

F11 — Reporting

Generate an executive report and a technical report from the claim ledger. An optional LLM layer may phrase findings in natural language, constrained to the structured findings JSON and validated against numeric tokens not present in its input. It is disabled by default during evaluation.

F12 — Dashboard

Six sections: overview, VPN configuration colour-coded by provenance tier, interactive SA state machine, traffic analysis with the class timeline, security assessment with coverage, and an evidence explorer reaching individual frames.

Live mode patches the dashboard over WebSocket per closed window.

F13 — Testbed

Generate labelled captures across the configuration matrix, with ground truth emitted automatically from kernel state rather than written by hand.

Testbed and dataset

Configuration matrix

Dimension	Values
Implementation	strongSwan, libreswan
Mode	Tunnel, transport
Encryption	AES-128-CBC, AES-256-CBC, AES-128-GCM, AES-256-GCM
Integrity	HMAC-SHA-256, HMAC-SHA-384, none for AEAD
DH group	2, 14, 19, 20
PFS	Enabled, disabled
IP version	IPv4, IPv6
IKE version	IKEv2 primary, IKEv1 subset
Network conditions	Clean, plus <code>tc netem</code> delay, jitter and loss profiles

Two implementations is a requirement, not a nicety. A fingerprint database built from one implementation cannot demonstrate that it discriminates between any.

Ground truth comes from the kernel

Each capture session dumps `ip xfrm state` and `ip xfrm policy` alongside the `swanctl` configuration.

This gives the true ESP cipher, integrity algorithm, mode, replay window, ESN setting and lifetimes — exactly the parameters the passive inference engine is trying to recover. It is the oracle every inference in F5 and F8 is scored against, and it eliminates the label noise that hand-written ground truth introduces.

Decrypt-assisted validation

In the lab the keys are yours. Export them, decrypt ESP in Wireshark, and recover the true composition of traffic inside each tunnel.

This is used only to validate the classifier, never in the product path. It is what lets the project state that its encrypted-traffic inferences were checked against decrypted ground truth rather than assumed correct — and it is the only way to get honest labels for mixed tunnel-mode windows.

Traffic generation

sipp or pjsua for VoIP, ffmpeg or an HLS server for streaming, curl and a headless browser for web, iperf3 for bulk, scp for file transfer, swaks for email, ping for ICMP.

Each capture is stored with a metadata record giving the full configuration, the traffic class, the generation parameters, the netem profile and the kernel state dump.

Deliberate crossing

Every traffic class must appear under multiple VPN configurations, and every configuration must carry multiple traffic classes.

Without this the config and the class are correlated, the classifier learns the correlation, and the reported accuracy is an artefact of the experimental design rather than a measurement of anything.

ML methodology and anti-leakage protocol

A lab dataset will hand you 99% accuracy that means nothing. This section exists to prevent that, and a reviewer will probe exactly these points.

Splitting

Random splitting is prohibited. Use grouped splits along three axes: leave-one-configuration-out, leave-one-endpoint-pair-out, and leave-one-capture-session-out.

The test set must contain VPN configurations never seen during training. Report per-configuration accuracy, never pooled accuracy alone — pooled numbers hide the case where the model works on three configs and fails on the fourth.

Excluded features

SPI, source and destination address, port number, absolute timestamp. Each identifies the capture session directly.

A second class of exclusion matters as much and is easier to miss: **the generator is the label**. Traffic-class labels come from which tool was run — iperf3, ffmpeg, sipp, swaks — not from kernel state, so any feature that identifies the generator rather than the behaviour is leakage in the same way a session identifier is. iperf3's default port, ffmpeg's characteristic startup burst, sipp's fixed SSRC pattern and swaks' predictable envelope sizes are all generator artefacts. Vary generator parameters across captures so that generator identity and behaviour class are decorrelated the way configuration and class already are. This is the one leakage channel that kernel-derived ground truth does not close, because kernel state supplies the crypto labels that score F5, F6b and F8 — it never supplies the traffic-class labels that train F7.

Protocol context features such as IKE version and mode are permitted only after demonstrating on crossed data that they do not carry class information. In an uncrossed testbed they are pure leakage.

Negative controls

Four checks, all reported. The third follows [SoK: Decoding the Enigma of Encrypted Network Traffic Classifiers](#), which ran 348 occlusion experiments and found that much of the field's reported accuracy came from models reading plaintext or session artefacts rather than behaviour. The fourth targets the label-provenance channel that kernel-derived ground truth does not close.

1. **Label shuffle.** Retrain on randomized labels. Accuracy must collapse to chance. If it does not, features are leaking session identity.
2. **Config-only baseline.** Train using only protocol context features, no behavioural features. High accuracy here means the testbed is correlated, not that the model works.
3. **Feature occlusion.** Retrain with each feature group removed in turn and report the accuracy delta per group. A group whose removal costs nothing was not doing work; a group whose removal collapses the model is carrying the result alone and needs justifying. Retransmission and inter-packet timing features are the specific risk here — they sit squarely in the temporal-overfitting category the SoK identifies, and they are not permitted in the shipped model without an occlusion result that survives a leave-one-configuration-out fold.

4. **Generator-identity probe.** Train a model to predict which generator produced each window instead of its behaviour class. High accuracy means generator artefacts survive in the feature set, and the class model is partly reading the tool rather than the traffic. Run this against the same feature set the shipped model uses, not a reduced one.

Calibration and abstention evaluation

Calibration is measured with reliability diagrams and expected calibration error on held-out data.

Abstention uses clustered conformal prediction rather than the marginal or the plain classwise variant, and the choice is forced by a documented failure mode. Under classwise (Mondrian) conformal, any class holding fewer than $1/\alpha - 1$ calibration examples receives an infinite quantile, so that class enters every prediction set regardless of score and abstention becomes decorative. At 90% coverage the floor is ten calibration examples per class, and even at exactly ten there is roughly a 10.7% probability that the class's realised coverage falls below 80% — both results from [Ding et al., Class-Conditional Conformal Prediction with Many Classes](#). Seven classes, a few hundred captures and leave-one-configuration-out folds will put the rare classes under that floor routinely, so plain Mondrian would degrade abstention rather than repair it. Clustered conformal groups classes by score distribution and pools calibration within the cluster, recovering most of the class-conditional guarantee without the data starvation.

The per-class calibration count is therefore a precondition, checked and logged at fit time rather than assumed. A fold whose rare class falls below the floor reports that fact and abstains from claiming coverage, instead of silently emitting a degenerate prediction set that contains everything.

Two distinct problems should not be conflated here. Clustering fixes class imbalance. It does not fix exchangeability, which a leave-one-configuration-out fold deliberately violates. Coverage will degrade on unseen configurations under any conformal variant; expect that, report it, and treat the degradation measurement as a finding about generalization rather than a failure of the method.

Known difficulties to report honestly

Control and keepalive traffic is trivially separable and will inflate pooled accuracy; report per-class metrics.

Bulk transfer, file transfer and progressive-download streaming are not cleanly separable by behaviour, which is why the taxonomy collapses them.

Mixed windows in tunnel mode have no single correct label. Evaluate twice: single-label metrics on pure windows, and composition error on all windows.

Security policy and recommendations

One reference set, cited precisely. Breadth across many compliance frameworks buys nothing and dilutes the citations.

Reference	Covers
RFC 8221	ESP and AH algorithm requirements
RFC 8247	IKEv2 algorithm requirements
RFC 4303	ESP packet framing — the arithmetic F6b rests on
RFC 9370	Multiple key exchanges in IKEv2; hybrid post-quantum detection
draft-ietf-ipsecme-ikev2-downgrade-prevention-08	Notify 16447 and downgrade exposure
NIST SP 800-77 Rev 1	IPsec VPN deployment guidance
NIST SP 800-57 Part 1	Key management and comparable strengths

Rule categories

The threat matrix groups findings into the nine categories the problem statement names: protocol, encryption, integrity, key exchange, PFS, SA, replay, metadata and ML confidence.

Each rule declares its minimum provenance tier, so a rule that would otherwise fire on a fingerprint default instead records a coverage gap.

Metadata exposure is measured, not asserted

Most tools treat metadata leakage as a checkbox. This platform reports it as a number, using the classifier it already has.

An observer on the path recovers the traffic class from timing and size alone with 0.93 confidence. That is the deployment's metadata leakage.

This turns the AI engine and the security finding into the same artefact, gives the problem statement's metadata-exposure requirement a real metric, and demonstrates the control working when traffic-flow confidentiality padding is enabled and the number drops.

How recommendations are phrased

Every recommendation is an area for review, never an instruction to execute.

"Review the negotiated DH group against a policy requiring at least 112-bit security" is in scope. "Set `ike = aes256-sha256-modp2048`" is not, because the system is working partly from inference and a confidently wrong config change breaks a working VPN.

Where a recommendation rests on an inferred claim, the report says so in the recommendation itself.

Scope and decisions

MVP

PCAP ingestion and live capture on one path. IKE parsing for IKEv1 and IKEv2. SA reconstruction with rekey lineage. The notify-posture and downgrade-exposure module. The ESP suite constraint engine with verdict lifting. The control-plane inference engine covering PFS, auth method, mode, rekey type and rekey interval. Implementation fingerprinting across two implementations. Windowed ESP feature extraction with cipher normalization. The gradient-boosted classifier with calibration and conformal abstention. SHAP explanation. The policy engine with coverage reporting. Risk, coverage and confidence scores. Executive and technical reports. The dashboard with provenance colouring and the evidence explorer. The testbed with kernel-derived ground truth.

Stretch

The 1D-CNN comparator. A FlowPic-style image representation as a side-by-side comparator only — the [IMC 2023 replication](#) confirmed most of the original results but found a 20% accuracy drop in some scenarios from dataset shift, and an image representation forfeits both feature occlusion and per-feature SHAP, which is why it

cannot be a candidate for the shipped model in a platform that sells auditability. ESN inference. Decrypt-assisted validation beyond a sample. Baseline-deviation anomaly detection for tunnelled exfiltration. The LLM narrative layer.

Additional implementation profiles beyond the two built in the lab is listed last here but is the highest-value stretch item on the list. The binding constraint on every model in this document is configuration diversity, not sample count — which is why self-supervised pretraining on cheap unlabelled captures was considered and rejected. More captures of the same two stacks produce more samples of the same handful of configurations, and the leave-one-configuration-out fold will say so. A third and fourth implementation improves every number in this document; nothing else on this list does.

Out

Automated remediation and configuration generation. Multi-agent orchestration. LSTM, Bi-LSTM and Transformer models. Deep AH analysis. Application-level identification such as naming WhatsApp. Multiple compliance frameworks. Continuous monitoring.

Decisions log

Decision	Reasoning
Cut LSTM and Transformer	A few hundred captures cannot support the parameter count; GBDT wins and trains in seconds
Cut AH generation	Effectively obsolete; detect and flag, do not spend testbed time on it
Kept live capture	Windowing was required anyway for tunnel mode, which makes the live path nearly free
Added replay-as-live	Removes demo risk while exercising the identical code path
Collapsed four feature views to two	View 4's features duplicated Views 1 and 2 under new names
Cut multi-framework compliance	One well-cited reference set is more defensible than four shallow ones
Merged the AI dashboard tab	A separate tab implies the AI is a bolt-on, contradicting the architecture

Decision	Reasoning
Kept multi-agent cut	The v1 reasoning was correct and the section is worth keeping in the submission
Promoted fingerprinting to MVP	It is the mechanism that bridges the observability gap
Kept risk and confidence scores	The problem statement names them; produce both with decomposition rather than dropping them

Related work and competitive position

No published work recovers ESP cipher and integrity parameters from a passive capture. That gap is the opportunity and the credibility risk in equal measure, so the position below states what is borrowed, what is new, and what is deliberately not cited.

Closest precedent. [Izadinia, Kourie and Eloff, "Uncovering identities: A study into VPN tunnel fingerprinting"](#) (Computers & Security, 2006) established that IKE implementations carry a structural fingerprint, identifying 18 discriminants of which SA attribute-type ordering — their TAVO fingerprint — alone separated three stacks. It covers three implementations on IKEv1 only, with lab captures and hand-written ground truth. This platform's advance over it is IKEv2 coverage, kernel-derived ground truth and a configuration matrix rather than three point configurations.

Methodology template. ["OpenVPN is Open to VPN Fingerprinting"](#) (USENIX Security 2022) reports a 0.0039% false-positive rate, three orders of magnitude better than prior ML approaches, and leaves 393 of 3,638 flagged flows explicitly unclassified rather than forcing a label. The conservative-classification discipline is adopted directly and is the published precedent for this platform's abstention tiers. Its active prober is out of scope for a passive tool.

Lineage. F8 is structurally the TLS-fingerprinting move — read the plaintext handshake, identify the stack, apply what is known about it — developed in JA3/JA4 and in Cisco's Joy, Mercury and EVE line. The honest framing is "JA3 for IKE, extended to constrain unobserved child-SA parameters", with the extension as the contribution. [Imperfect Forward Secrecy](#) (CCS 2015) established IPsec key-exchange weakness as an internet-scale measured problem and is the reason DH-group scoring exists at all.

Theory for the length channel. [On Fingerprinting Attacks and Length-Hiding Encryption](#) bounds what ciphertext length leaks and supplies the trivial-advantage vocabulary; note that it assumes the cipher mode is already known, so it frames the leak rather than performing the inference. Vaudenay's [Security Flaws Induced by CBC Padding](#) (EUROCRYPT 2002) is the classic treatment of CBC padding structure in IPsec.

Deliberately not cited as support. A large literature claims to identify AES from DES from Blowfish out of raw ciphertext using CNNs. It works in ECB mode with fixed keys and collapses under AEAD, where unique IVs guarantee that identical plaintexts produce different ciphertexts. It appears in this project only as the approach that was evaluated and rejected, with the reason stated.

The competitive field

Problem statement SIH26160 has several public repositories already. Three are relevant to positioning.

Project	State	Overlap	Gap
CipherGuard	31 commits, 151 tests, CLI, REST API, Docker testbed	RFC 4303 residue analysis, ML ranking, plausibility mask, framing-identical suites acknowledged	Its own README states the ESP model has never seen a real tunnel
TunnelScope	3 commits, no visible tests	Packet-length residue method, same premise	No validation methodology visible
netsentry-ai, CipherLens, IPsecAnalyzer, SIH26160-Alchemist	Early	General IPsec audit framing	No deterministic ESP mechanism in evidence

The design has converged industry-wide on residue analysis, so that alone is not a differentiator. Five things separate this platform, and they are the things to lead with: the notify-posture module in F3b, which postdates every one of these repositories and the IETF draft it implements; the GCD-of-differences estimator, which needs no assumption about plaintext length where a fixed residue lookup does; the known-plaintext-length anchor that resolves ICV exactly; the TFC gate that prevents silent garbage; and verdict

lifting, which converts irreducible ambiguity into decidable risk answers. Behind all five sits the claim ledger and the no-promotion rule, which no competitor repository has in any form.

The testbed remains the moat. Real tunnels with kernel-verified labels are what none of these projects have, and every accuracy number in this document depends on them existing.

Requirement traceability

Every item the problem statement names, and where it is satisfied.

Problem statement item	Satisfied by	Note
(a) Tunnel and transport mode	F13 testbed matrix	Both generated
(a) AES-128, AES-256, GCM, CBC+HMAC	F13 testbed matrix	All four
(a) Different DH groups	F13 testbed matrix	Groups 2, 14, 19, 20
(a) PFS enabled and disabled	F13 testbed matrix	Both
(a) IPv4 and IPv6	F13 testbed matrix	Both
(a) Traffic types incl. VoIP, email, web, ICMP, video	F13 traffic generation	Mapped to seven behavioural classes
(b) Capture via Wireshark, tcpdump, custom	F1 ingestion	tcpdump and AF_PACKET
(b) IKE negotiation, ESP, AH, normal comms	F2, F3	AH detected and flagged, not deeply analysed
(c) IPsec protocol identification	F2	Observed
(c) IKE version	F3	Observed
(c) Tunnel or transport mode	F5	Inferred; encrypted in IKEv2

Problem statement item	Satisfied by	Note
(c) Encryption algorithm	F3 for IKE SA, F8 for ESP	ESP value is a fingerprint default
(c) Authentication algorithm	F3, F5	Mixed observed and inferred
(c) Key exchange method	F3	Observed
(c) SA characteristics	F4	Graph with rekey lineage
(c) Predict traffic type inside ESP	F7	Windowed ML classification
(d) Cryptographic strength	F9	Rule-based
(d) Configuration compliance	F9, F10	Against the declared reference set
(d) SA parameters	F4, F9	
(d) Key lifetime	F5	Measured rekey interval, not parsed config
(d) Replay protection	F9	Reported <code>not_observable</code> with reasoning
(d) Forward secrecy	F5	Inferred from rekey message size
(d) Cipher suite strength	F9	
(d) Metadata exposure	F9	Measured as classifier recovery rate
(e) Security score	F10	With coverage and decomposition
(e) Executive and technical report	F11	Both
(e) Risk score	F10	Published formula
(e) Threat matrix	F9	Nine categories
(e) AI confidence score	F10	Decomposed by subsystem

Named deliverables

Working prototype, AI classification engine, interactive dashboard, security assessment report, demonstration video, technical documentation and the training dataset are all covered by F1-F13 plus this document and the architecture walkthrough.

Two items in (c) and (d) are answered differently from what the wording implies, and the reports say so rather than hiding it. Mode, PFS and the ESP algorithms are inferred rather than read, because IKEv2 encrypts them. Replay protection is reported as unobservable, because it is receiver-side policy that no capture can reveal.

Evaluation plan

Every claim the platform makes about itself must be a measured number with a stated method.

Protocol analysis

Accuracy of IPsec detection, IKE version identification and IKE SA parameter extraction, scored against the swanctl configuration. These should be at or near 100%; anything lower indicates a parsing defect, not a hard problem.

Control-plane inference — the differentiator's proof

Each inference in F5 is scored against `ip xfrm` ground truth, reported separately with its abstention rate.

Inference	Target	Fallback if below target
PFS from rekey size	85% on MODP, 70% on ECP	Demote to indicative tier
Rekey type	100%	Structural; investigate defect
Auth method	85%	Report cert-vs-other only
Tunnel vs transport	80% where not abstaining	Rely on topology signal alone
Implementation match	90% top-1 on known, no false match on unknown	Raise distance threshold

Abstention rate is reported alongside accuracy in every row. An inference that is 95% accurate while abstaining 80% of the time is a different product than one that is 85% accurate while abstaining 10% of the time, and the report must let a reader tell them apart.

Traffic classification

Accuracy, macro-F1, per-class precision and recall, confusion matrix, expected calibration error, conformal coverage, and abstention quality — all reported per configuration group, not pooled.

Composition error is reported separately for mixed tunnel-mode windows.

Security assessment

Detection rate on intentionally weak configurations planted in the testbed, false-positive rate on known-good configurations, evidence traceability (every finding reaches a frame), and policy-rule coverage.

System

Analysis time per capture, flows and windows processed per second, report generation time, live-mode latency from window close to dashboard update, and behaviour on the degradation cases: mid-session start, truncation, non-IPsec input, packet loss.

The one number that matters most

Coverage on a mid-session capture. It is the realistic operating condition, most tools handle it badly, and handling it well is the clearest demonstration that the provenance model does real work.

Build plan

Ordered so that a working end-to-end system exists before any differentiator is attempted, and so that the deterministic differentiators land before the probabilistic ones. Every differentiator is independently droppable without breaking the pipeline.

```
flowchart TD
    M1[Baseline pipeline] --> M2[Notify posture]
    M2 --> M3[Testbed + dataset]
    M3 --> M4[ESP constraint engine]
    M4 --> M5[Control-plane inference]
    M5 --> M6[Classifier]
    M6 --> M7[Deterministic identity]
    M7 --> M8[Polish + evaluation]
```

Milestone 1 — Baseline pipeline. Ingestion, demux, IKE parsing via tshark, SA reconstruction, the claim ledger with the elimination-versus-ranking valve enforced in the type, and a policy engine with five rules. Output is a technical report with no ML. This alone satisfies a meaningful slice of the problem statement and de-risks everything after it.

Milestone 2 — Notify posture and downgrade exposure. The 16447 four-state lattice, RFC 9370 hybrid post-quantum detection, the PPK signals, the severity matrix. Tested against synthetic `IKE_SA_INIT` messages, so it carries no testbed dependency and delivers the platform's headline finding before a single capture exists. Moved to second position for exactly that reason.

Milestone 3 — Testbed and dataset. The configuration matrix, kernel-state ground truth, traffic generation, netem profiles. Ends with a labelled dataset and the crossing property verified. Every accuracy number in this document depends on this milestone, which is why nothing that claims a number precedes it.

Milestone 4 — ESP constraint engine. The GCD granularity estimator, the known-plaintext-length anchor solver, the TFC gate, candidate-set output and verdict lifting. Each component is unit-tested against synthetic ESP framing before the testbed exists,

then scored against `ip xfrm` truth once it does.

Milestone 5 — Control-plane inference. PFS, rekey type, auth method, mode, rekey interval. Each scored against `ip xfrm` ground truth before it ships.

Milestone 6 — Classifier. Windowed features with cipher normalization, LightGBM, calibration, conformal abstention, SHAP. Ends with all three anti-leakage controls run and reported, feature occlusion included.

Milestone 7 — Deterministic identity. Vendor ID exact lookup with version parse, the CVE affected-range table, structural fingerprint fallback with distance matching, provenance labelling across both paths.

Milestone 8 — Polish. Dashboard completion, executive report, live mode and replay-as-live, degradation handling, evaluation write-up, demonstration video.

Sequencing logic

The ordering inverts v2. Deterministic differentiators sit at milestones 2 and 4; probabilistic ones at 6 and 7. Under time pressure the cuts therefore come off the machine learning rather than off the determinism, which leaves the strongest findings intact rather than the weakest. Milestone 2 in particular is cheap, unblocked and novel, so it is the wrong thing to leave until last.

If they are attempted first and run long, there is no working system to demonstrate at all. That is the most common way projects of this shape fail.

Stress test

A second-pass critique of this document, written against itself. Each item names where a claim could fail and what the fallback is.

Where the differentiators could break

PFS-from-size may not survive real conditions. RFC 7383 fragmentation splits large messages, and some implementations pad the `SK{}` payload. Both blur the size signal the inference depends on. Mitigation: reassemble fragments before measuring, and score the inference against `ip xfrm` truth rather than asserting it works. If measured accuracy falls below 70%, demote it to an indicative signal and say so — a documented negative result is still a contribution.

The fingerprint database covers only what you built. Two implementations in a lab gives two profiles. Real deployments include Cisco, Fortinet, Juniper, pfSense and Mikrotik. The risk is overclaiming generality. Mitigation: always report a ranked match with a distance score, return an explicit unknown result past a threshold, and describe the profile set honestly as two implementations rather than as a fingerprint library.

Mode inference needs traffic it may not get. The size-arithmetic signal requires packets near the MTU ceiling. A VoIP-only or ICMP-only capture offers none. Mitigation: gate on a minimum count of near-MTU packets, abstain otherwise, and fall back to the topology signal.

Conformal prediction assumes exchangeability that leave-one-config-out deliberately breaks. Coverage will degrade on unseen configurations. This is expected and must be reported rather than concealed; the degradation measurement is itself the finding.

Windowed classification creates boundary ambiguity. Windows spanning a transition have no single correct label. Mitigation: dual evaluation — single-label on pure windows, composition error on all.

Residual risks

Risk	Mitigation
Dataset too small for stable estimates	<code>tc netem</code> profiles multiply conditions legitimately; split netem profiles across train and test too
Scoring weights look arbitrary	Publish them in the policy file; include a sensitivity note
LLM layer hallucinates in a security report	Off by default; numeric-token validator; structured input only
Coverage reporting reads as weakness	Frame it as rigor; show side by side what a naive tool would have claimed
Live demo fails on the day	Replay-as-live exercises the identical path deterministically
Differentiators eat the schedule	Deterministic milestones 2 and 4 precede the probabilistic 6 and 7, so cuts come off ML first

Risk	Mitigation
Adversary shapes traffic to evade the tool	Only F7 is evadable. Notify presence is a protocol fact and framing arithmetic a protocol constraint, so neither responds to shaping; deliberate padding pushes F6b to <code>not_observable</code> through the TFC gate rather than to a wrong answer. Moving weight from ML to determinism shrank this surface rather than widening it
Generator artefacts leak into traffic-class labels	Generator artefacts are on the excluded-feature list and the generator-identity probe tests for residue

What this PRD still does not resolve

Three things are genuinely open and should be treated as open rather than papered over.

The first is how much the fingerprint-default mechanism is still worth. v3 demoted it from primary mechanism to tie-breaker inside the feasible set F6b produces, which narrows the open question rather than closing it: how often does that feasible set contain members that actually disagree on a policy predicate? If verdict lifting resolves most captures on its own, F8's contribution to ESP assessment is close to nil and the effort belongs in coverage instead. This is measurable on the testbed and should be measured early, not argued about.

The second is whether seven traffic classes are separable at the accuracy the reports imply. If per-class recall on the mushier classes lands near chance, collapsing further to four is better than reporting a confusion matrix that undermines the rest of the work.

The third is the honest limit of the whole product. Against a capture that starts mid-session on an IKEv2 deployment, this platform can say very little with certainty — and its main contribution in that case is knowing and stating that, which is a real contribution but a modest one. The reports should not oversell it.